To obtain a certificate-bound access token the client simply authenticates to the token endpoint with the client certificate when obtaining an access token. If the AS supports the feature, then it will associate a SHA-256 hash of the client certificate with the access token. The API receiving an access token from a client can check for a certificate binding in one of two ways:

- If using the token introspection endpoint (section 7.4.1 of chapter 7), the AS will return a new field of the form `"cnf": { "x5t#S256": "…hash…" }` where the hash is the base64url-encoded certificate hash. The `cnf` claim communicates a *confirmation key*, and the `x5t#S256` part is the *confirmation method* being used.
- If the token is a JWT, then the same information will be included in the JWT claims set as a `"cnf"` claim with the same format.

  DEFINITION A ***confirmation key*** communicates to the API how it can verify a constraint on who can use an access token. The client must confirm that it has access to the corresponding private key using the indicated ***confirmation method***. For certificate-bound access tokens the confirmation key is a SHA-256 hash of the client certificate and the client confirms possession of the private key by authenticating TLS connections to the API with the same certificate.

Figure 11.7 shows the process by which an API enforces a certificate-bound access token using token introspection. When the client accesses the API, it presents its access